

Directory Auditor

What an attacker would find in your directory — one file, read-only, five minutes.

Open source · Apache 2.0

Windows · Linux · macOS

AD · Samba AD DC · FreeIPA · OpenLDAP · Entra ID

Concept brief
October 2026
CLI: `dirauditor`

1 file

No install, no runtime, no account, no licence key

≤ 5 min

From download to a report on screen, zero configuration

~80 %

Of findings need only a normal user's read access

0 bytes

Leave the machine — no telemetry, no cloud, no auto-update

WHAT IT IS

A free security auditor for directory services and everything around them. It reads the directory the way an attacker would and reports misconfigurations and known-exploitable conditions in the **directory core** (ACLs, delegation, privileged groups, trusts), **DNS** (zone rights, insecure dynamic updates, wildcard records), **Group Policy** (GPO and SYSVOL rights, GPP passwords, scripts), **PKI** (AD CS templates and CAs, ESC1-13), **Kerberos**, **credential management** (LAPS, gMSA, Protected Users) and **integrated applications** (Exchange, SCCM, Entra Connect).

One engine, several directories: Active Directory and Samba AD DC first (which also covers РЕД АДМ and Альт Домен), then FreeIPA / ALD Pro and OpenLDAP, then Entra ID.

HOW IT RUNS



- Double-click on Windows or `./dirauditor` on Linux: a local web wizard detects the domain and your identity and offers **Scan now**.
- Runs as your current logon over Kerberos; works against hardened DCs (LDAP signing, channel binding, LDAPS).
- Console mode for jump hosts; flags for scheduled runs and CI; `--demo` shows a full report without any domain. Quick scan first, full scan one click later.

WHAT YOU GET

- A **0–100 score** overall and per area; **top 5 paths to Tier 0**; **quick wins** fixable in ten minutes.
- Every finding with why it matters, how it is abused, the exact fix command (PowerShell, `ldapmodify`, `samba-tool`, `ipa`) and how to verify; `fix --plan` writes a dry-run script for the findings you select.
- Self-contained HTML report in English or Russian, plus JSON and CSV; **diff** between runs; **redaction** for sharing outside the team; what was checked, passed and skipped, and why.

PRIVILEGE TIERS

TIER	IDENTITY	ACCESS	SHARE OF VALUE
0	Any domain user	LDAP read only	~80 %
1	Any domain user	+ SYSVOL, DNS, LDAP/SMB probes	~15 %
2	Admin, opt-in	+ DC registry and services	~5 %

STATUS AND OPEN DECISIONS

Concept stage. Open: engine language (Go vs .NET Native AOT), governance, Russian software-registry route, Astra Linux signing in v1. Wanted: pilot domains, contributors, reviewers.

WHY IT IS SAFE TO RUN ON PRODUCTION

- Read-only, provably.** No write paths are compiled in; every release ships a test showing the binary contains no LDAP modify, SMB write or DNS update code — any reviewer can reproduce it.
- No exploit code.** Vulnerabilities are inferred from versions, flags and ACLs; nothing is attempted, relayed or sprayed; no account can be locked out.
- Signed and reproducible.** Authenticode with immediate SmartScreen reputation, cosign/minisign for Linux and macOS, Astra Linux 3ПЦ signature; reproducible builds, SBOM, SLSA provenance.
- Transparent.** Checks are readable, signed YAML packs; `--dry-run` prints which DCs and queries a run will touch — paste it into the change ticket.

HOW IT DIFFERS FROM EXISTING TOOLS

	EXISTING FREE AUDITORS	DIRECTORY AUDITOR
Runs on	Windows only	Windows, Linux, macOS
Directories	Active Directory (and Entra ID)	AD, Samba AD DC, FreeIPA, OpenLDAP, Entra ID
Russian stack	Not covered	РЕД АДМ, Альт Домен, ALD Pro, Astra Linux
Licence	Proprietary or restricted free edition	Apache 2.0, no expiry
Dependencies	.NET runtime	None — one static file
Checks	Compiled in	Readable, signed packs; community can add checks

BUILT FOR ENTERPRISE APPROVAL

Every release ships a CI-generated **security review pack**: threat model, network-interactions sheet, full query manifest, SBOM, provenance, scan results, SOC runbook with expected EDR alerts, personal-data inventory, read-only proof. Plus MSI / .deb / .rpm packages, a least-privilege audit-account script, and per-check mappings to CIS, NIST SP 800-53, ISO 27001, PCI DSS 4.0, DORA, ГОСТ Р 57580, ФСТЭК, БДУ.

ROADMAP

v1 — alpha

AD + Samba AD DC; core, DNS, GPO, PKI, Kerberos; web wizard; review pack

v2

FreeIPA / ALD Pro, OpenLDAP; fix plans; diff and scheduled runs; community packs

v3

Entra ID; tier-2 collectors; consultant mode; independent audit